

PROJECT REPORT

Project 3: Phishing Awareness Analysis

Building the Human Firewall: Threat Detection & Triage

Goal	Analyze sample emails and messages to identify phishing attempts.
Key Skills	Threat analysis, awareness of cyber attacks, security thinking
Deliverables	Red-flag checklist, annotated sample analysis, triage decision tree
Status	Complete

1. Objective

The modern cybersecurity perimeter is no longer the network firewall it is the user. This project analyzes sample phishing emails and messages to identify suspicious links and keywords, catalog the red flags that expose an attack, and explain why each message is unsafe. The output is a practical, non-expert triage toolkit that turns awareness into a repeatable, actionable process.

Key Requirements

- Identify suspicious links or keywords
- List red flags found in phishing messages
- Explain why the message is unsafe
- Produce a usable triage checklist and decision tree for incoming threats

2. Why This Matters: The Human Firewall

Technical firewalls cannot compensate for human error. In a controlled red-team simulation (the Citadel engagement), 40% of employees fell for a simulated phishing and vishing campaign, and it took an attacker an average of just 82 seconds to get their first click. Industry-wide, roughly 80% of security breaches involve a phishing component.

A real-world example of the stakes: the Quanta Computer exploit, where a single attacker stole over \$100 million from Google and Facebook not through a zero-day exploit, but through highly targeted spear-phishing. By spoofing the domain of a legitimate hardware supplier and forging supporting invoices, the attacker bypassed finance department checks completely.

3. Analytical Framework: Input → Process → Output

Stage	Description
Input (The Bait)	The delivery method and technical disguise — phishing type and domain spoofing technique used
Process (Psychology)	The cognitive trigger that forces the user to bypass logical verification

Output (Defense)	The triage decision and simulation/training response that closes the gap
-------------------------	--

3.1 The Hierarchy of Email Targeting

Type	Description
Mass Phishing	Generic lures mimicking ubiquitous brands (Amazon, PayPal). High volume, low personalization — roughly 1% engagement.
Spear Phishing	Contextual precision. Attackers use OSINT (e.g. LinkedIn) to reference real project names, colleagues, or internal jargon.
Whaling	Targets the C-suite. Focuses on founders and executives to execute high-value wire transfers (BEC) or acquire M&A documents.

3.2 Channels Beyond the Inbox

- Smishing (SMS) — malicious links via text, often disguised as package deliveries or bank alerts
- Vishing (Voice) — live calls using caller-ID spoofing to impersonate IT support or law enforcement
- Quishing (QR Codes) — malicious codes on posters or PDFs that push users to unmanaged mobile devices
- Search Engine Phishing — SEO poisoning that ranks lookalike sites above legitimate login portals
- Callback Phishing (TOAD) — an email with no malicious link, only a phone number to call, moving the attack off text-based filters entirely

4. Suspicious Links: Domain Spoofing Techniques

Identifying a malicious link starts with recognizing how attackers disguise a URL to look legitimate:

Technique	Example
Typosquatting	amaz0n.com (zero substituted for the letter O)
Homoglyph Attack	paypal.com using a Cyrillic "a" that is visually identical to the Latin "a"
Combosquatting	yourcompany-secure-login.com a security-sounding word appended to a real brand
Subdomain Trap	www.decode labs.tech.login-update.com the true root domain (login-update.com) is buried after a fake, trusted-looking subdomain. Always read a URL right to left to find the real root.

A related infrastructure risk is Dangling DNS Takeover: when a company deletes a cloud resource (like an AWS S3 bucket) but forgets to remove the matching DNS record, an attacker can provision a new resource under that same trusted name — taking over a legitimate corporate subdomain without ever touching the company's own systems.

5. The Psychology: Cognitive Triggers

Every phishing message relies on a psychological lever to make the target act before they verify:

Trigger	Mechanism
Authority	Impersonating the C-suite, IT, or law enforcement to demand unquestioned compliance
Urgency	Artificial time pressure ("Account locked in 30 minutes") to trigger fight-or-flight and reduce rational processing
Curiosity	Exploiting the need to fill a knowledge gap ("See what your colleague said about you")
Fear / Greed	Threatening consequences (legal action) or promising unearned rewards (prize giveaways)

6. Sample Message Analysis

Three representative samples, annotated with the specific red flags that expose them and an explanation of why each is unsafe.

Sample 1 — Fake Microsoft Sign-In Alert (Email)

```
From: Microsoft Support <support@logins-updates.com>
Subject: FW: Urgent: Your Account Security Alert

[Forwarded thread with pasted headers and mismatched timestamps]

Microsoft – Sign In
Username or password
[Sign In]

Attachments: Security_Update_2024.iso
```

Suspicious elements identified:

- Sender-domain mismatch — display name says "Microsoft Support" but the routing domain is logins-updates.com, not microsoft.com
- Fake forwarded chain — an "FW:" thread with pasted headers the user was never actually part of, used to manufacture false legitimacy
- Browser-in-the-Browser (BitB) — the sign-in box is a fake pop-up rendered inside the page, not a real browser window (it cannot be dragged outside the page)
- Dangerous attachment — a .iso file, an uncommon extension for a "security update," commonly used to smuggle malware past email filters

Verdict: MALICIOUS — Block sender domain & escalate to security team. Do not enter credentials or open the attachment.

Sample 2 — CEO Wire Transfer Request (SMS / BEC)

```
Message Today 9:47 AM
From: "CEO"

I lost my wallet at the airport.
Need you to wire transfer funds
for my flight immediately.
- CEO
```

Suspicious elements identified:

- Authority + urgency stacked together — impersonates a senior executive and demands immediate financial action, a classic Business Email Compromise (BEC) pattern
- Unverifiable channel — arrives as a bare SMS from an unsaved number, with no secondary confirmation offered
- Bypass request — implicitly asks the recipient to skip normal payment-authorization procedure because the "CEO" is unreachable by normal means
- Emotionally engineered scenario ("lost wallet," "immediately") designed to short-circuit careful verification

Verdict: MALICIOUS — Do not send funds. Verify by calling the executive directly on a known number before taking any action.

Sample 3 — Legitimate Internal Status Update (Control Example)

Sender: Project Manager <sarah.lee@company.com>
Subject: Q3 Project Status Update - Non-Urgent

Hi Team,

Please review the attached project status for Q3
at your earliest convenience.

No immediate action is required.

Thanks,
Sarah.

Attachment: Q3_Status.pdf

Why this is safe:

- Sender's display name matches the underlying domain (company.com)
- No urgency, secrecy, or bypass language explicitly says "no immediate action required"
- Standard file type (.pdf) referenced by name, not a disguised or unusual attachment
- Content is contextually consistent with the sender's known role

Verdict: SAFE — Close. No action needed beyond normal review.

7. Red Flag Reference Checklist

A consolidated list of the 11 red flags to check when triaging any inbound message:

#	Red Flag
1	Sender-Domain Mismatch — display name conflicts with the actual routing domain
2	Fake Forwarded Chains — "FW:" threads with pasted headers and odd timestamps
3	Browser-in-the-Browser (BitB) — fake SSO pop-ups that cannot be dragged outside the window
4	Dangerous Attachments — uncommon extensions (.iso, .js, .scr) or HTML smuggling links
5	Urgent Bypass Requests — demands for secrecy or skipping standard procedure
6	Requests for Sensitive Info — unexpected prompts for MFA codes, passwords, or payment detail changes
7	Activity Alerts — alarmist sign-in warnings pointing straight to a login page
8	MFA Fatigue — repeated, unprompted authenticator push notifications
9	Security Callback Scams (TOAD) — no malicious link, only a phone number to call
10	QR Code Prompts — unsolicited QR codes that push the user to mobile, bypassing desktop URL filters
11	Deepfake Live-Meeting Fraud — audio/video impersonation of an executive demanding a payment change mid-call

8. Triage Decision Tree

Every triage event must end in one of three definitive actions:

Incoming Suspicious Email Safe Suspicious Malicious Close Warn User Block Domain & Escalate		
Category	Signal	Action
Safe	Sender verified, no urgency/bypass language, standard file types	Close no further action
Suspicious	One or two mild red flags (e.g. unexpected but plausible request)	Warn user, advise verification before acting

Malicious	Multiple clear red flags or a confirmed spoof / dangerous attachment	Block sender domain and escalate to the security team
------------------	--	---

9. The Golden Rule: Pause, Verify, Report

Step	Action
1. Pause	Recognize the cognitive trigger (urgency, fear, authority) and stop interacting with the message. Apply the Five-Minute Rule before responding.
2. Verify	Confirm the request through a secondary, out-of-band channel e.g. if the request came by email, verify by phone using a known directory number.
3. Report	Use the internal reporting mechanism. Do not simply delete the email reporting lets the security team purge the threat from every other inbox it reached.

10. Conclusion

Phishing exploits the space between a technical control and a human reaction. This project demonstrates that most attacks regardless of channel (email, SMS, voice, or QR) share a repeatable structure: a technical disguise (the bait), a psychological trigger (the manipulation), and a set of observable red flags (the tell). By systematically checking sender domains, URLs, attachment types, and request language against this checklist, and by routing every message through a clear Safe / Suspicious / Malicious decision tree, an organization turns individual awareness into a consistent, scalable defense the Human Firewall.